

Аудит IT-инфраструктуры предприятия партнёра

Проект: ERP-система для кафе/ресторана (CafeHelp / CafeSystem)

Партнёр: Шакур Дмитрий

Смоделированная IT-компания: ООО «КейфТех» (CafeTech Solutions) – разработчик и интегратор ERP.

1. Описание предприятия

Название: ООО «КейфТех» (CafeTech Solutions)

Сфера деятельности: Разработка, внедрение и сопровождение ERP-систем для кафе, ресторанов, сетей быстрого питания.

Размер: 45 сотрудников (12 разработчиков, 5 тестировщиков, 4 DevOps, 6 техподдержки, 8 внедренцев, 10 административных).

Бизнес-процессы, зависящие от IT:

1. Разработка и тестирование ПО (CI/CD, управление релизами).
2. Обслуживание клиентской инфраструктуры (мониторинг, инциденты).
3. Внутренняя операционная деятельность (учёт времени, документооборот).

Роль IT: Ключевая. Без IT невозможна поставка обновлений клиентам, мониторинг и коммуникации.

Основные IT-системы:

- Разработка: GitLab, Jira, SonarQube, Docker Registry.
- Обслуживание: Zabbix/Prometheus+Grafana, GLPI, TeamViewer.
- Внутренние: 1C:УНФ, Bitrix24, Nextcloud.

2. Инвентаризация IT-инфраструктуры

Аппаратное обеспечение (10+ позиций)

Тип	Модель	ОС	Кол-во	Состояние
Сервер сборки CI	Dell PowerEdge R750 (64GB RAM)	Ubuntu 22.04	2	Хорошее
Сервер БД (внутренний)	HP ProLiant DL380 (128GB)	Debian 12	1	Удовл. (5 лет)
Сервер мониторинга	SuperMicro (32GB, 2TB HDD)	Ubuntu 20.04	1	Износ HDD
Сервер резервного копирования	QNAP TS-873A (48TB)	QTS	1	Новый
Рабочая станция	Dell Precision	Windows 11	12	Хорошее

Тип	Модель	ОС	Кол-во	Состояние
разработчика (12)	3660 (32GB)			
Рабочая станция тестировщика (5)	Lenovo ThinkCentre M75s (16GB)	Windows 10	5	Хорошее
Ноутбук техподдержки (6)	MacBook Pro M1	macOS	4	Хорошее
Офисный ПК (10)	Dell OptiPlex 3080 (8GB)	Astra Linux	10	Удовл. (мало RAM)
Маршрутизатор (ядро)	MikroTik CCR1036	RouterOS	2 (кластер)	Хорошее
Коммутатор доступа	Cisco Catalyst 2960-X	IOS	3	Устаревает

Общая оценка: достаточное, но сервер мониторинга требует замены HDD, офисным ПК нужно увеличить RAM.

Программное обеспечение

- ОС: Ubuntu 22.04/24.04, Debian 12, Windows 11, macOS, Astra Linux.
- БД: PostgreSQL 14, MySQL 8, Redis.
- Прикладное: GitLab CE, Jira+Confluence, Zabbix 6.4, Grafana, Docker+Portainer, 1C:УНФ, Bitrix24.
- Лицензирование: корпоративные подписки на Windows/Astra, Jira (25 юзеров), 1C платная. Лицензионная чистота соблюдена.

Сетевая инфраструктура

- Локальная сеть: 1 Гбит/с, VLAN (develop, production-internal, management, guest).
- Доступ в интернет: два провайдера (Ростелеком + МТС) с failover.
- VPN: OpenVPN для удалённых сотрудников.
- DMZ для публичных сервисов (GitLab, Grafana).

3. Безопасность IT-инфраструктуры

Анализ рисков (3+ угрозы)

Угроза	Вероятность	Потенциальный ущерб	Существующие меры	Эффективность
Фишинг / компрометация учётки	Средняя	Утечка кода, доступ к клиентам	Политика паролей, фишинг-тренинг	Частично (нет MFA везде)

Угроза	Вероятность	Потенциальный ущерб	Существующие меры	Эффективность
Атака на цепочку поставок (npm/PyPI)	Низкая	Компрометация сборок	Проверенные репозитории	Слабая (нет SBOM)
Отказ сервера мониторинга (HDD)	Средняя	Потеря данных о клиентах	RAID 1, ежедневный бэкап	Высокая (но нет горячей замены)
Физический доступ в серверную	Низкая	Кража оборудования	Электрозамок, видео	Высокая

Оценка мер безопасности

- Антивирус: Dr.Web (Windows), ClamAV (серверы).
- Брандмауэр: на маршрутизаторе, VLAN.
- Политика паролей: 8 символов, смена 90 дней.
- MFA: только GitLab и Jira (GA). На серверах и 1C – нет.
- Резервное копирование: ежедневно на QNAP + еженедельно в S3. RPO ~1 день, RTO не определён.

Итог: меры достаточны для рядовых угроз, но требуется MFA и сканирование зависимостей.

4. Рекомендации по управлению проектом модернизации

Цель: обеспечить отказоустойчивость и наблюдаемость для 100+ клиентов.

Задачи:

1. Перевести мониторинг на кластер (3 узла).
2. Внедрить централизованный сбор логов (ELK/Loki).
3. Заменить ручной деплой на ArgoCD/Flux.
4. Разработать DR Plan (RTO ≤ 4 ч, RPO ≤ 15 мин).

План проекта (4 этапа)

Этап	Содержание	Срок	Ответственный
1	Анализ и закупка оборудования (3 сервера, SSD)	1 мес	DevOps
2	Кластер мониторинга (Prometheus+Thanos, Grafana)	2 мес	Системный администратор
3	Централизованное	1 мес	Разработчик +

Этап	Содержание	Срок	Ответственный
	логирование		DevOps
4	DR Plan и учения (PostgreSQL, GitLab)	1 мес	Команда поддержки

Управление рисками

Риск	Вероятность	Меры смягчения
Перегрузка персонала	Высокая	Нанять внешнего подрядчика, сократить не срочные задачи
Проблемы совместимости	Средняя	Тестирование в песочнице, поэтапный rollout
Отказ оборудования при миграции	Низкая	Миграция в нерабочее время, горячий резерв

Коммуникации

- Внутренние: DevOps, разработчики, поддержка, финдиректор.
- Внешние: клиенты – уведомление за 2 недели.
- Каналы: Slack (синки), Confluence (дашборд), Telegram (аварии).

5. Сильные стороны

- Сегментация VLAN и кластер маршрутизаторов.
- Два провайдера с failover.
- Регулярное резервное копирование в облако.

6. Замечания

- Нет MFA на критических внутренних сервисах (1С, серверы БД).
- Старый сервер мониторинга – SPOF.
- Нет формального DR Plan с RTO/RPO.
- Документация разрознена (Confluence + Word).

7. Итоговые рекомендации (приоритеты)

- **P0:** Внедрить MFA на все сервисы с клиентскими данными.
- **P0:** Заменить сервер мониторинга на кластер из 3 узлов.
- **P0:** Разработать DR Plan с RTO/RPO, провести учения в течение 3 месяцев.
- **P1:** Внедрить централизованный сбор логов (ELK).

- **P1:** Создать единую архитектурную схему в draw.io.

Ожидаемый эффект: повышение устойчивости с 4/10 до 8/10, возможность обслуживать 100+ клиентов без увеличения штата.